Detailed Answers: Information System Auditing Exercises & Case Studies

Exercise 1: Understanding IS Auditing

Q1: Define IS auditing, its scope, and its importance in cybersecurity.

- **Definition:** Information System (IS) auditing is a systematic process of evaluating and verifying IT systems, infrastructure, and security controls to ensure compliance, efficiency, and risk management.
- **Scope:** Includes IT governance, risk management, data integrity, security policies, and regulatory compliance.
- **Importance:**
  - Ensures data protection and security.
  - Identifies vulnerabilities and mitigates risks.
  - Enhances regulatory compliance (e.g., GDPR, HIPAA).

Q2: Compare IT Audit, Security Audit, and Financial Audit.

Aspect	IT Audit	Security Audit	Financial Audit
Focus	IT systems, infrastructure	Cybersecurity policies, risks	Financial records, transactions
Purpose	Efficiency, compliance	Data protection, risk assessment	Financial accuracy, fraud detection
Standards	COBIT, ISO 27001	NIST, ISO 27001	SOX, GAAP, IFRS

Exercise 2: Applying IS Audit Frameworks & Standards

Q1: Which frameworks are most suitable for a financial institution and why?

- **COBIT**: IT governance and risk management.
- **ISO 27001**: Ensures information security management.
- **NIST Cybersecurity Framework**: Enhances resilience against cyber threats.

Q2: Implementation Roadmap for Compliance

1. Risk Assessment
2. Define Security Policies
3. Implement Controls
4. Monitor & Evaluate
5. Continuous Improvement

Q3: How can compliance be measured?

- Regular audits and assessments
- Security performance metrics
- Compliance reports

Exercise 3: Compliance Auditing

Q1: Identify gaps in the provider's IS audit process.

- Weak access controls
- Lack of employee cybersecurity training
- Inadequate encryption of sensitive data

Q2: Suggest corrective actions.

- Implement role-based access control (RBAC)
- Conduct mandatory cybersecurity training
- Apply end-to-end encryption

Q3: Recommendations to prevent future violations.

- Regular security audits
- Automated compliance monitoring
- Establish an incident response team

Exercise 4: Technical Audit

Q1: Potential vulnerabilities in an e-commerce platform.

- Unpatched software
- Weak password policies
- Poor network segmentation

Q2: Recommended penetration testing strategies.

- External and internal penetration testing
- Social engineering tests
- API security testing

Q3: Log analysis and anomaly detection.

- Identify unusual login patterns
- Monitor failed authentication attempts
- Investigate unauthorized data access